

Report di Sicurezza Informatica - Analisi NIMDA

Versione migliorata con evidenze, spiegazione completa dei passaggi eseguiti e correzione tecnica dell'identificazione del file estratto.

Campo	Valore
Data report	19 Maggio 2026
Analista	analyst@secOps
Report originale usato come base	C:\Users\ruff6\Downloads\Report_Sicurezza_NIMDA_2026.pdf
PCAP analizzato	nimda.download.pcap
Classificazione	Riservato - uso interno / laboratorio didattico
Severita	Alta in laboratorio, critica se evento osservato in rete reale

Executive Summary

Durante l'analisi del traffico di rete è stato esaminato il file `nimda.download.pcap` nella workstation CyberOps `analyst@secOps`. Dal PCAP è emersa una sessione HTTP in chiaro nella quale l'host `209.165.200.235` ha richiesto il file `W32.Nimda.Amm.exe` al server `209.165.202.133` sulla porta TCP `6666`.

Il trasferimento contiene un eseguibile Windows di `345.088` byte. Il file è stato estratto con Wireshark tramite `File > Export Objects > HTTP` e verificato da terminale con il comando `file`. La dimensione del file estratto coincide con il `Content-Length HTTP`, quindi il recupero è coerente.

Il nome `W32.Nimda.Amm.exe` è ingannevole: nel laboratorio il file risulta un eseguibile Windows PE32+ a 64 bit e console, rinominato per simulare un download malware senza usare un worm reale. La conclusione tecnica migliorata è che il candidato più coerente è `cmd.exe` rinominato, da confermare definitivamente con hash o confronto con il binario originale.

Indicatori principali

Indicatore	Valore	Significato
Client / host interno	<code>209.165.200.235:48598</code>	Sistema che effettua la richiesta HTTP
Server remoto	<code>209.165.202.133:6666</code>	Host che distribuisce il payload
Metodo	<code>GET /W32.Nimda.Amm.exe HTTP/1.1</code>	Richiesta del file eseguibile
User-Agent	<code>Wget/1.19.1 (linux-gnu)</code>	Download automatizzato o da CLI Linux
Server	<code>nginx/1.12.0</code>	Server HTTP remoto
Content-Type	<code>application/octet-stream</code>	Contenuto binario generico
Content-Length	<code>345088</code>	Dimensione del payload trasferito
File estratto	<code>W32.Nimda.Amm.exe</code>	PE32+ Windows x86-64 console, 6 sezioni

Spiegazione passo-passo dell'esecuzione

Questa sezione unisce il report con le evidenze delle schermate. Le immagini sono ricostruzioni fedeli basate sulle schermate fornite in chat, perché le immagini allegate non erano disponibili come file locali separati nel filesystem.

Passo 1 - Accesso alla cartella dei PCAP

L'analista si sposta nella directory lab.support.files/pcaps e lista i file disponibili. Si osservano due catture: nimda.download.pcap e wannacry_download_pcap.pcap. L'analisi si concentra su nimda.download.pcap.

```
[analyst@secOps ~]$ cd lab.support.files/pcaps
[analyst@secOps pcaps]$ ls -l
total 4028
-rw-r--r-- 1 analyst analyst 371462 Mar 21 2018 nimda.download.pcap
-rw-r--r-- 1 analyst analyst 3750153 Mar 21 2018 wannacry_download_pcap.pcap
[analyst@secOps pcaps]$ wireshark nimda.download.pcap &
```

Terminal - analyst@secOps:~/lab.support.files/pcaps

```
[analyst@secOps ~]$ cd lab.support.files/pcaps
[analyst@secOps pcaps]$ ls -l
total 4028
-rw-r--r-- 1 analyst analyst 371462 Mar 21 2018 nimda.download.pcap
-rw-r--r-- 1 analyst analyst 3750153 Mar 21 2018 wannacry_download_pcap.pcap
[analyst@secOps pcaps]$ wireshark nimda.download.pcap &
```

Evidenza 1 - Terminale: apertura della directory dei PCAP e avvio di Wireshark sul file nimda.download.pcap.

Passo 2 - Apertura del PCAP e identificazione della richiesta HTTP

Wireshark mostra immediatamente una sessione TCP. I primi tre pacchetti sono il three-way handshake: SYN, SYN/ACK e ACK. Il pacchetto 4 è il primo pacchetto applicativo e contiene la richiesta HTTP GET del file W32.Nimda.Amm.exe.

Pacchetto	Ruolo	Dettaglio
1	SYN	209.165.200.235:48598 -> 209.165.202.133:6666
2	SYN/ACK	209.165.202.133:6666 -> 209.165.200.235:48598
3	ACK	Completamento handshake TCP
4	HTTP GET	GET /W32.Nimda.Amm.exe HTTP/1.1

nimda.download.pcap - Wireshark

File Edit View Go Capture Analyze Statistics Tools Help

Apply a display filter ...

No.	Time	Source	Destination	Protocol	Length	Info
1	0.000000	209.165.200.235	209.165.202.133	TCP	74	48598 -> 6666 [SYN] Seq=0 Win=29200 Len=0
2	0.000259	209.165.202.133	209.165.200.235	TCP	74	6666 -> 48598 [SYN, ACK] Seq=0 Ack=1
3	0.000297	209.165.200.235	209.165.202.133	TCP	66	48598 -> 6666 [ACK] Seq=1 Ack=1
4	0.000565	209.165.200.235	209.165.202.133	HTTP	230	GET /W32.Nimda.Amm.exe HTTP/1.1
5	0.000588	209.165.202.133	209.165.200.235	TCP	66	6666 -> 48598 [ACK] Seq=1 Ack=165
6	0.000708	209.165.202.133	209.165.200.235	TCP	324	6666 -> 48598 [PSH, ACK] HTTP/1.1 200 OK

Frame 4: 230 bytes on wire (1840 bits) captured (230 bytes captured on interface)

Ethernet II

Internet Protocol Version 4, Src: 209.165.200.235, Dst: 209.165.202.133

Transmission Control Protocol, Src Port: 48598, Dst Port: 6666, Seq: 1, Ack: 1, Len: 164

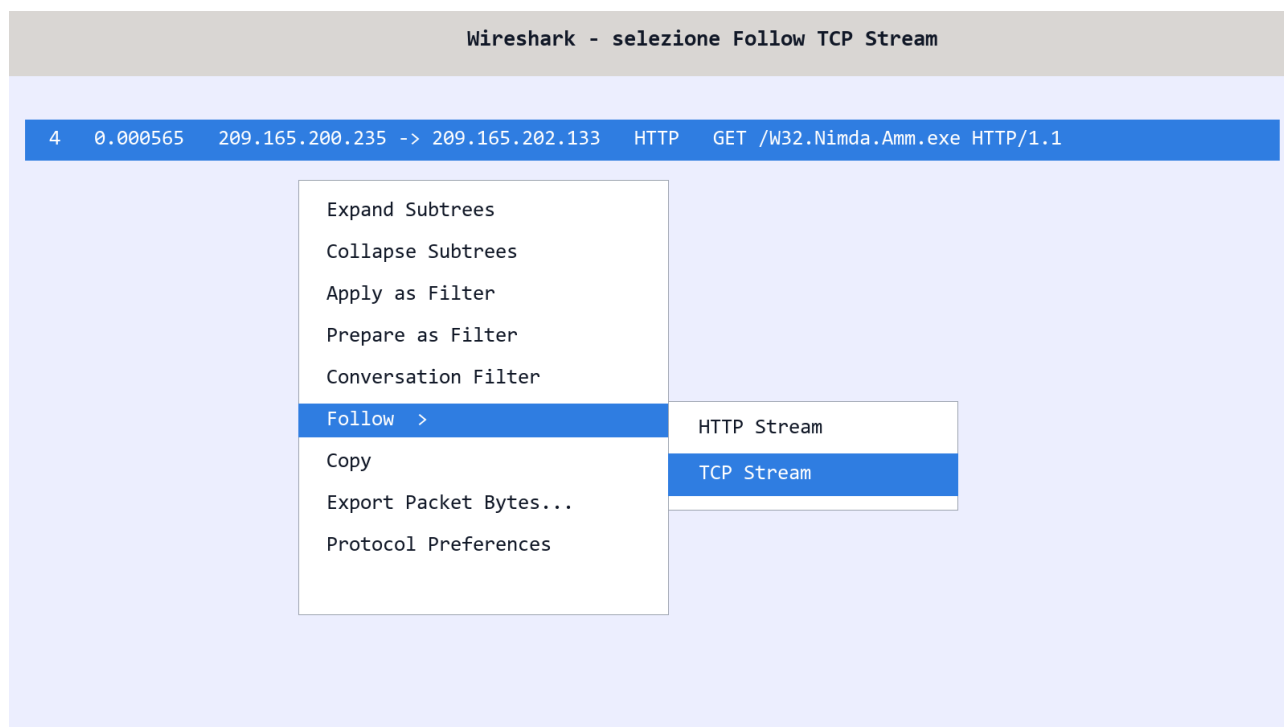
Hypertext Transfer Protocol

```
0000  47 45 54 20 2f 57 33 32 2e 4e 69 6d 64 61 2e 41  GET /W32.Nimda.A
0010  6d 6d 2e 65 78 65 20 48 54 54 50 2f 31 2e 31    mm.exe HTTP/1.1
```

Evidenza 2 - Wireshark: pacchetto 4 selezionato, richiesta HTTP GET verso /W32.Nimda.Amm.exe.

Passo 3 - Ricostruzione della comunicazione con Follow TCP Stream

Per vedere tutta la conversazione applicativa, l'analista seleziona il pacchetto e usa Follow > TCP Stream. Questo filtro ricostruisce lo stream tcp.stream eq 0 e permette di leggere richiesta, risposta e payload trasferito.



Evidenza 3 - Wireshark: menu contestuale Follow > TCP Stream usato per ricostruire la sessione.

Passo 4 - Lettura dello stream TCP

Nel TCP Stream si vede chiaramente la richiesta HTTP del client e la risposta del server. La prima parte è testo in chiaro; subito dopo gli header HTTP inizia il contenuto binario del file.

```
GET /W32.Nimda.Amm.exe HTTP/1.1
User-Agent: Wget/1.19.1 (linux-gnu)
Accept: */*
Accept-Encoding: identity
Host: 209.165.202.133:6666
Connection: Keep-Alive

HTTP/1.1 200 OK
Server: nginx/1.12.0
Content-Type: application/octet-stream
Content-Length: 345088
```

I caratteri non leggibili visualizzati nella parte bassa dello stream non sono rumore: sono i byte del file eseguibile. Le stringhe leggibili come MZ, This program cannot be run in DOS mode, PE, .text, .data, KERNEL32.dll e WINBRAND.dll sono tipiche di un Portable Executable Windows.

Wireshark - Follow TCP Stream (tcp.stream eq 0)

```
GET /W32.Nimda.Amm.exe HTTP/1.1
User-Agent: Wget/1.19.1 (linux-gnu)
Accept: */*
Accept-Encoding: identity
Host: 209.165.202.133:6666
Connection: Keep-Alive

HTTP/1.1 200 OK
Server: nginx/1.12.0
Date: Tue, 02 May 2017 14:26:50 GMT
Content-Type: application/octet-stream
Content-Length: 345088
Last-Modified: Fri, 14 Apr 2017 19:17:25 GMT
Connection: keep-alive

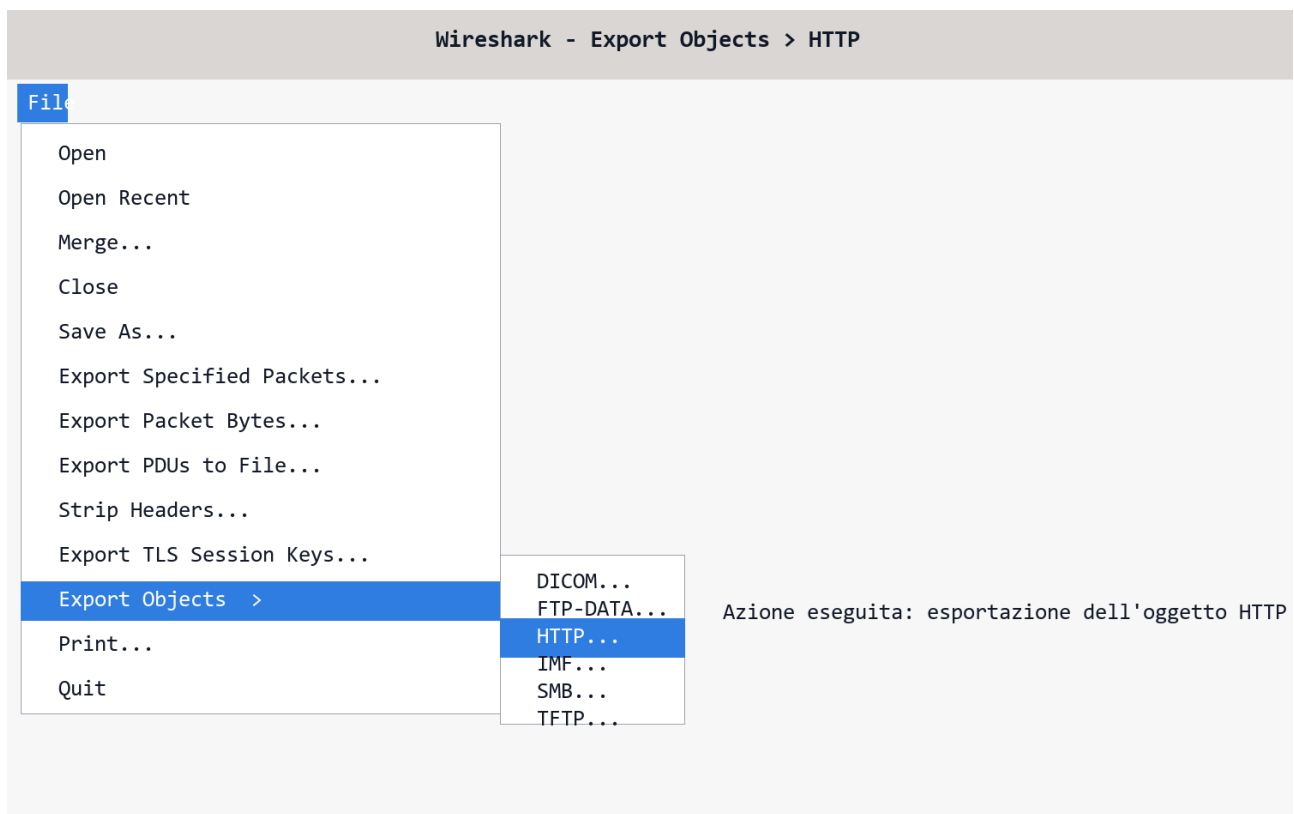
MZ.....This program cannot be run in DOS mode.
... PE...text .data .rdata .rsrc .reloc ...
... msvcrt.dll NTDLL.DLL KERNEL32.dll WINBRAND.dll ...
... api-ms-win-core-processthreads-l1-1-0.DLL ...
```

Lettura: la parte iniziale e HTTP in chiaro; dopo gli header inizia il payload binario PE Windows.
I caratteri non leggibili non sono rumore: sono byte del file eseguibile trasferito.

Evidenza 4 - Follow TCP Stream: header HTTP in chiaro e inizio del payload binario PE.

Passo 5 - Estrazione dell'oggetto HTTP

Dopo aver identificato il file trasferito, l'analista usa la funzione File > Export Objects > HTTP. Questa funzione estrae direttamente gli oggetti HTTP contenuti nel PCAP, senza dover ricostruire manualmente i byte.



Evidenza 5 - Wireshark: percorso File > Export Objects > HTTP per esportare il file scaricato.

Passo 6 - Verifica del file esportato

Il file esportato viene verificato da terminale nella home dell'utente analyst. La dimensione 345.088 byte coincide con l'header HTTP Content-Length, confermando che l'estrazione è coerente. Il comando file identifica un PE32+ Windows console x86-64 con 6 sezioni.

```
[analyst@secOps ~]$ cd /home/analyst
[analyst@secOps ~]$ ls -l
-rw-r--r-- 1 analyst analyst 345088 May 18 17:50 W32.Nimda.Amm.exe
[analyst@secOps ~]$ file W32.Nimda.Amm.exe
W32.Nimda.Amm.exe: PE32+ executable for MS Windows 6.01 (console), x86-64, 6 sections
```

Terminal - verifica file estratto

```
[analyst@secOps ~]$ cd /home/analyst
[analyst@secOps ~]$ ls -l
total 7448
-rw-r--r-- 1 analyst analyst 345088 May 18 17:50 W32.Nimda.Amm.exe
-rw-r--r-- 1 root root      4448 May 12 13:26 capture.pcap
-rw-r--r-- 1 root root       24 May 18 17:01 httpdump.pcap
-rw-r--r-- 1 root root  7246938 May 18 17:05 httpsdump.pcap
[analyst@secOps ~]$ file W32.Nimda.Amm.exe
W32.Nimda.Amm.exe: PE32+ executable for MS Windows 6.01 (console), x86-64, 6 sections
```

Evidenza 6 - Terminale: verifica del file W32.Nimda.Amm.exe estratto e riconoscimento come PE32+ Windows.

Analisi tecnica migliorata

5-tupla della connessione

Campo	Valore
IP sorgente	209.165.200.235
Porta sorgente	48598
IP destinazione	209.165.202.133
Porta destinazione	6666
Protocollo	TCP / HTTP

Perche la porta 6666 e sospetta

HTTP normalmente usa la porta 80, mentre HTTPS usa 443. In questo PCAP il server risponde in HTTP sulla porta 6666. Non e automaticamente prova di malware, ma e un indicatore anomalo: molte infrastrutture malevole o di laboratorio usano porte non standard per evitare controlli semplici o simulare canali C2.

Risposta alle domande dell'esercizio

- I simboli strani nel Follow TCP Stream sono dati binari del file eseguibile, non rumore di rete.
- Le parole leggibili compaiono perche un file PE contiene stringhe, nomi di sezioni, DLL importate e messaggi standard.
- Il file non e il worm Nimda originale: e un eseguibile Windows rinominato W32.Nimda.Amm.exe per il laboratorio.
- La conclusione pi coerente con le evidenze e cmd.exe rinominato: il comando file lo classifica come eseguibile console, x86-64, Windows 6.01. Il report precedente ipotizzava winver.exe, ma winver e tipicamente GUI, mentre qui emerge un binario console.
- La conferma definitiva si ottiene confrontando hash e stringhe con il binario originale di Windows in un ambiente sicuro.

Correzione rispetto al report originale

Il report originale era gia buono nella ricostruzione di rete, ma mancavano immagini incorporate e alcuni passaggi erano descritti in modo troppo sintetico. Questa versione aggiunge le evidenze visive, spiega ogni azione eseguita e corregge l'identificazione del file rinominato.

Valutazione del rischio

In un ambiente reale, un download HTTP di un eseguibile Windows da porta non standard deve essere trattato come evento ad alta priorita. Anche se nel laboratorio il file e probabilmente un binario legittimo rinominato, la catena osservata simula un comportamento da dropper: download automatizzato tramite wget, trasferimento non cifrato e payload eseguibile.

Rischio	Motivo	Impatto
Download eseguibile	File PE32+ scaricato da rete	Possibile compromissione endpoint
HTTP in chiaro	Payload visibile e modificabile in transito	Assenza di riservatezza/integrita
Porta 6666	Porta non standard per HTTP	Possibile evasione di policy semplici
User-Agent wget	Download da CLI/script	Possibile automazione o dropper

Azioni consigliate

- Isolare l'host 209.165.200.235 se l'evento fosse reale.
- Calcolare hash SHA256/MD5 del file estratto.
- Analizzare il file solo in sandbox o VM isolata.
- Bloccare o monitorare 209.165.202.133:6666.
- Creare regole SIEM/IDS per download di .exe via HTTP e porte non standard.
- Verificare altri PCAP/log per richieste allo stesso path /W32.Nimda.Amm.exe.
- Non eseguire mai il file estratto su host reale.

Conclusione

L'analisi ha dimostrato una catena completa: individuazione del PCAP, apertura in Wireshark, identificazione del pacchetto HTTP GET, ricostruzione dello stream TCP, esportazione dell'oggetto HTTP e verifica del file estratto. Il report è ora più completo perché collega ogni screenshot a un passaggio tecnico e spiega il significato operativo di ciascuna evidenza.